

امنیت — THREAT MODEL

نگاشت. WP-G3. خانه رسمی اصل ۴/۵ حاکمیتی. (tool gateway / least-privilege / no-SPOF).
KB. سبک + جدول. تهدید × کنترل STRIDE.

خلاصه سریع.

و کلیدهای، (مالی/PII) داده مشتری، (ورودی نامعتمد) lead/محتوای اسکرپ شده: Brushline سطح حمله integration. انسان روی هر کنش بیرونی، sandbox اجرای ابزار در، scoped key با tool-gateway: کنترلها. kill switch، و hash-chained audit.

مرز اعتماد ۱.

```
flowchart TB
    subgraph UNTRUSTED["نامعتمد"]
        SCR["lead enquiry / محتوای اسکرپ شده"]
        WEB["SERP / وب"]
    end
    subgraph TRUSTED["مرز اعتماد Brushline"]
        ORCH["Orchestrator"]
        GW["Tool Gateway (scoped, sandbox)"]
        STORE["Data store (PII جدا)"]
    end
    subgraph EXTERNAL["بیرونی"]
        SM8["ServiceM8/Tradify"]
        CH["Channels"]
    end
    SCR -->|sanitize/treat as data| ORCH
    WEB -->|read-only| ORCH
    ORCH --> GW
    GW -->|scoped key| SM8
    GW -->|after human approval| CH
    STORE -. "PII never to memory/LANGAR." .-> ORCH
```

KB × سبک × کنترل STRIDE ۲.

تهدید	مثال	کنترل	KB
Spoofing	جعل منبع lead/sender	sender-ID/ABN, auth کانال	KB-03/07
Tampering	دستکاری لاگ draft	hash-chained append-only	KB-06
Repudiation	انکار تصمیم	audit با actor/ts	KB-06
Information disclosure	مالی/PII نشی	INV-2, scoped store, no-memory-PII	KB-04/09
DoS / runaway	حلقه هزینه	spend cap + kill switch	INV-3/CONFIG
Elevation	scope فراتر از tool	least-privilege, scoped key, sandbox	KB-01
Prompt injection	دستور در محتوای اسکریپ شده	data نه instruction! = محتوای بیرونی Gate! human approval	KB-07/05

۳. کنترل‌های پایه

۱. **Tool gateway** — gateway! scoped API key! no anonymous reach. ۲. **Sandbox** (مثل لازم scope فقط — **Least-privilege**. جدا. ۳. container/microVM اجرای ابزار/کد در — **ServiceM8 minimal scopes**). ۴. **HITL** — publish/send/sync (INV-1) انسان روی هر — ۵. **Kill switch + circuit breaker** — توقف فوری (INV-3). ۶. **Audit** — hash chain برای tamper-evidence (KB-06). ۷. **PII boundary** — memory/LANGAR/AI جداسازی سخت داده حساس! هرگز در — (INV-2). عمومی

۴. prompt injection (تأکید ویژه)

ممکن است دستور خصمانه داشته باشد. قاعده: (enquiry صفحه رقیب، متن، review) محتوای اسکریپ شده Gate + human این محتوا همیشه داده است نه دستور! هیچ‌گاه مستقیم به کنش بیرونی ترجمه نمی‌شود! لایه دفاع‌اند approval

۵. نگاشت حاکمیتی (۷ اصل)

را (no-SPOF/separation of duties) و ۵ (tool gateway/least-privilege) این سند مستقیماً اصل ۴ وصل می‌شود (eval/guardrails) و ۷ (observability/audit)، ۳ (HITL/kill switch) پوشش می‌دهد و به ۲

۵.۵ Multi-tenant (افزادگی برای کاملی)

می‌رسد، سطح حمله عوض می‌شود: (چند کسب‌وکار نقاشی) tenant به چند Operator از یک Brushline وقتی tenant یک memory/audit/داده) tenant بزرگ‌ترین ریسک = نشتب بین (در دستری دیگری tenant).

```

flowchart TB
    subgraph T_A["Tenant A"]
        DA["data store A (PII)"]
        MA["memory store A"]
        AA["audit chain A"]
    end
    subgraph T_B["Tenant B"]
        DB["data store B (PII)"]
        MB["memory store B"]
        AB["audit chain B"]
    end
    GW["Tool Gateway (tenant-scoped key)"]
    GW -->|فقط key_A| T_A
    GW -->|فقط key_B| T_B
    T_A -. no cross-read .-> T_B

```

کنترل	STRIDE	multi-tenant تهدید
isolation store! tenant_id روی هر رکورد؛ no shared memory	Info disclosure	بین PII/نشبت داده tenant
memory store جدا per-tenant! provenance! scope بسته	Tampering/Elevation	memory poisoning tenant بین
scoped key per-tenant ! نه کلید سراسری! ServiceM8 OAuth per-tenant (نه API-Key مشترک)	Elevation	یک کلید blast radius مشترک
spend cap + kill switch per-tenant (CONFIG)	DoS	noisy neighbor / runaway یک tenant
! هرگز اشتراکی suppression list per-tenant	Compliance	تداخل consent/suppression
audit chain جدا per-tenant یا tenant-tag	Repudiation	audit اختلاط

! **per-tenant** kill switch و cap مشترک؛ (۲) کلید و store/memory/audit هیچ (۱) multi-tenant قواعد cross-tenant منتقل شود؛ (۴) تست «هیچ OAuth (multi) به API-Key (single) از ServiceM8 (۳) (۴) فاز ۰ «LANGAR هم‌راستا با تست «هیچ» فاز ۶ DoD در «read».

MVP. این بخش برای کاملی اضافه شد؛ اجرای آن متعلق به فاز ۶ (محصول‌سازی) است، نه

۶. قواعد سخت

۱. محتوای بیرونی = data، نه instruction. ۲. gateway scoped + sandbox هر کنش خارجی از. ۳. PII/همیشه در دسترس kill switch. ۴. (INV-2) مالی پشتِ مرز.

۷. قدم بعدی

KB-08. DoD:  ورودی/خروجی در guardrails، CONFIG، key های دقیق scope تعریف
قاعده‌مند،  بدون کد prompt-injection،  trust boundary،  KB،  STRIDE×کنترل×KB.